

ZUMBARL

The Ecosystem for Campus Talent

Storage Folder Structure

Cloudflare R2 bucket and object key architecture

Version 1.1 | June 2026 | Confidential

Overview

Zumbarl uses five separate Cloudflare R2 buckets rather than one bucket with internal folders. Separating by trust level means a misconfigured access policy on one bucket cannot accidentally expose another — the same isolation principle applied to the safety service in the backend architecture.

Bucket	Purpose
zumbarl-kyc-private	Identity documents, business registration files, safety report evidence. Never CDN-served.
zumbarl-gig-files	Gig briefs, submissions, deliverable proofs. Accessible only to gig participants and ops.
zumbarl-profile-private	Profile documents that aren't meant for public display — full CVs, internal notes, draft uploads.
zumbarl-public-assets	Avatars, portfolio media, company logos, marketplace photos. CDN-served, no auth.
zumbarl-generated	Platform-generated files — certificates, invoices, roadmap exports, reports.

Naming convention across every bucket: every object key starts with entity type and ID — students/{studentId}/... or companies/{companyId}/.... This makes account deletion a single prefix-based delete operation rather than a file-by-file loop that can partially fail.

Bucket 1 — zumbarl-kyc-private

Signed URLs only, 15-minute expiry. Never CDN-cached. Requires server-side request through a role-gated endpoint.

students/{studentId}/

- national-id-front.jpg
- national-id-back.jpg
- student-id-front.jpg
- student-id-back.jpg
- proof-of-enrollment.pdf

companies/{companyId}/

- certificate-of-incorporation.pdf
- owner-id.jpg
- kra-pin-certificate.pdf
- tax-compliance-certificate.pdf

safety-reports/{reportId}/

- evidence-{n}.jpg — *separate IAM token, Safety Officer role only*

The safety-reports prefix uses a completely separate R2 API token from the rest of this bucket. Backend services with general KYC-bucket read access cannot read it — only the Safety service's credentials can generate a signed URL here.

Bucket 2 — zumbarl-gig-files

Signed URLs, 1-hour expiry. Accessible to the company and student on a specific gig, plus the operations team for dispute review.

gigs/{gigId}/brief/

attachment-{n}.pdf — *reference files the company attached*

gigs/{gigId}/submissions/

v1/deliverable-{n}.{ext}

v2/deliverable-{n}.{ext} — *after a revision request*

gigs/{gigId}/proof/

checkin-photo.jpg — *in-app camera only, EXIF preserved*

checkout-photo.jpg

gigs/{gigId}/stats-evidence/

before-screenshot.png

after-screenshot.png

gigs/{gigId}/messages/

attachment-{messageId}.{ext} — *files shared in-chat during a gig*

Retention: gig files are deleted 90 days after completion unless the student has saved the item to their portfolio — in which case a copy moves to zumbarl-public-assets with the student's explicit consent.

Bucket 3 — zumbarl-profile-private

Profile-related documents that are not meant for public viewing — the working/internal versions, distinct from what's shown on a public portfolio. Signed URLs, 30-minute expiry.

students/{studentId}/

cv/cv-{timestamp}.pdf — *every CV upload versioned, full history kept*

draft-uploads/{fileId}.{ext} — *in-progress uploads before publishing to portfolio*

companies/{companyId}/

internal-notes/{studentId}/note-{n}.txt — *private notes on a pipeline student, company-only*

team-documents/{fileId}.{ext} — *internal company onboarding docs, not shown to students*

chamas/{chamaId}/

constitution.pdf — *group savings rules document, members only*

meeting-minutes/{date}.pdf

This bucket exists because not every private document is identity-related — a company's internal note on a student, or a chama's meeting minutes, need restricted access but don't belong in the KYC bucket's stricter, more limited-access tooling.

Bucket 4 — zumbarl-public-assets

Public read, CDN-cached through Cloudflare, no authentication required. Anything visible to any visitor, logged in or not.

students/{studentId}/

- avatar.jpg
- cover-banner.jpg — *profile header image*
- portfolio/{portfolioItemId}/thumbnail.jpg
- portfolio/{portfolioItemId}/full-{n}.jpg

companies/{companyId}/

- logo.png
- cover-image.jpg
- gallery/{n}.jpg — *office photos, team photos for company profile*

marketplace/{listingId}/

- photo-{n}.jpg

notes-library/{campusId}/{courseId}/

- {noteId}-preview.pdf — *preview only, full file gated behind purchase*

events/{eventId}/

- cover.jpg

clubs/{clubId}/

- logo.jpg
- gallery/{n}.jpg

platform/

- branding/logo-variants/... — *Zumbarl's own brand assets*

Bucket 5 — zumbarl-generated

Files the platform itself creates — never directly uploaded by a user. Signed URLs, 1-hour expiry, owner and relevant company only.

certificates/{studentId}/

{certificateId}.pdf — *tamper-evident, verification hash stored in DB*

invoices/{companyId}/

{transactionId}.pdf

roadmap-exports/{studentId}/

career-roadmap-{date}.pdf — *powers the "Download Roadmap" feature*

placement-contracts/{placementId}/

offer-letter.pdf

signed-agreement.pdf

reports/internal/

{reportType}-{date}.csv — *admin analytics exports, never public*

Certificates are the one file type that must never be deletable, even through normal Super Admin tooling. If fraud is discovered after issuance, revocation is a database flag — visible if someone verifies the certificate hash — not a file deletion. Deleting it would make verification return a false 'never existed' instead of an honest 'revoked.'

Access Policy Summary

Bucket	Access pattern + expiry
zumbarl-kyc-private	Signed URL, server-side request only, role-gated. 15-minute expiry. No CDN.
zumbarl-gig-files	Signed URL, gig participants + ops team only. 1-hour expiry. No CDN.
zumbarl-profile-private	Signed URL, owner + explicitly authorised viewer only. 30-minute expiry. No CDN.
zumbarl-public-assets	Public read, CDN-cached, no auth. Permanent — no expiry.
zumbarl-generated	Signed URL, owner + relevant company only. 1-hour expiry. No CDN.
safety-reports/ prefix	Signed URL, Safety Officer role exclusively, separate API token. 10-minute expiry.

- **Never store files in the database:** PostgreSQL holds the R2 object key and metadata only — size, MIME type, upload timestamp — never the binary. Keeps the database fast and backups small.
- **Signed URLs are generated per-request, never cached client-side:** The frontend requests a fresh signed URL from the backend every time a private file needs viewing. Access can be revoked instantly by changing a user's role — no stale URL keeps working after permissions change.
- **Upload constraints are enforced before any bytes transfer:** The backend issues a presigned upload URL with size and MIME type limits baked in — 50MB max for gig files, 10MB max for KYC images. Rejected client-side, never relying on post-upload validation alone.
- **Account deletion triggers a single prefix-wide purge:** A delete-by-prefix call against `students/{studentId}/` runs across all five buckets in one operation — not a file-by-file loop that can fail halfway through.

Zumbarl — The Ecosystem for Campus Talent
This document is confidential and intended for internal use only.